NEXUS — Открытые находки на `main` / Open Findings on `main`

Состояние на `463ab4269f761a2ecfb46eab39534a736d3a2227`, проверено в коде и на реальных базах в этой ветке.

State at `463ab426…`, checked in the code and against real databases on this branch.

Этот документ — честный список того, что НЕ исправлено. PR, к которому он приложен, закрывает целостность миграций и ничего больше.

This is the honest list of what is not fixed. The PR it accompanies closes migration integrity and nothing else.

RU · 1. Изоляция проектов на legacy-маршрутах — ОТКРЫТО (P1)

```
# orchestration/web_server.py @ 463ab426
2108:  if path == "/api/tasks":
2109:      return self._json(200, {"tasks": self.app.store.list_tasks_all()})
2060:  if path == "/api/dashboard":
2061:      return self._json(200, {"counts": self.app.store.dashboard_counts()})
```

`grep -c "_require_operator\|require_owner\|is_owner"` по `web_server.py` → 0.

Над этими маршрутами стоит только `_require_read()`, который спрашивает «есть ли credential», а не «можно ли этому пользователю».

Severity, честно. `AuthService.login` сверяется с одним username, поэтому штатно второй аккаунт не создать — дефект недостижим при однопользовательской эксплуатации. Но `resolve()` доверяет любой строке в `sessions`, а `_open_session()` создаёт сессию для любого имени. Как только появится multi-account (а `a112d456` уже добавил управление аккаунтами), это станет утечкой чужой работы между пространствами.

Почему не в этом PR. Исправление требует продуктового решения: к чему привязывать legacy-ресурсы, у которых нет `project_id` — к проекту (значит backfill и миграция данных), к владельцу развёртывания (значит single-tenant граница), или к аккаунту. Это решение владельца, а не побочный эффект починки миграций. Смешивать их в одном PR — значит сделать ревью невозможным.

Что предлагается отдельно: `authz.py` с единой точкой решения + гейт на всех legacy-маршрутах (404, а не 403, чтобы не различать «запрещено» и «не существует»). Готово и покрыто 12 тестами в ветке `nexus/mainline-recovery`; переносится отдельным PR после решения по модели.

EN · 1. Project isolation on legacy routes — OPEN (P1)

`/api/tasks` and `/api/dashboard` return `list_tasks_all()` / `dashboard_counts()` to any authenticated caller; zero ownership checks exist in the file. Severity is conditional today (one configured username) and unacceptable the moment a second

account exists — which `a112d456` just brought closer. Not fixed here because the fix needs a product decision (what legacy resources without `project_id` bind to), and folding that into a migration-integrity PR would make review impossible.

RU · 2. `/api/system` и `/api/config` — ИСПРАВЛЕНО В ЭТОМ PR

`system_info()` (`web_server.py:746`) и `/api/config` (`:2075`) читают `self.client.base_url`. Транспорт `direct` (`CloudDirectClient`) композирует `CloudClient` и своего `base_url` не имел, поэтому на транспорте по умолчанию оба диагностических эндпоинта отвечали `500`.

Воспроизведено на живом сервере, до правки:

```
/api/system  HTTP 500  {"error": "AttributeError: 'CloudDirectClient' object has no attribute 'base_url'"}
/api/config  HTTP 500  {"error": "AttributeError: 'CloudDirectClient' object has no attribute 'base_url'"}
```

Исправление — делегирующее свойство `CloudDirectClient.base_url` → внутренний `self.cloud.base_url` (одна точка истины, без второй копии URL, которая могла бы разойтись). После правки, тем же сценарием:

```
/api/system  HTTP 200  {"store": {"ok": true, ...}, "cloud": {"ok": false, "error": "unreachable", "url":
"https://app.all-hands.dev"}}
/api/config  HTTP 200  {"cloud_key": true, "cloud_url": "https://app.all-hands.dev", "transport": "direct", ..
.}
```

Регрессионный тест — `tests/test_cloud_direct.py::test_direct_transport_reports_the_cloud_base_url` (проверяет оба транспорта через публичный атрибут, а не через `hasattr` на классе).

Почему это оказалось в PR про миграции, честно. Потому что нашлось при подготовке прогона, чинится тремя строками и не меняет ни одного контракта. Держать его отдельным PR значило бы отправить владельцу отчёт, в котором диагностика не работает, ради формальной чистоты. Если ревьюер предпочтёт отдельный PR — правка удаляется из этой ветки без следа в остальном.

EN · 2. `/api/system` and `/api/config` — FIXED IN THIS PR

Both read `client.base_url`; `CloudDirectClient` composes a `CloudClient` and had no such attribute, so on the default transport both answered 500 — reproduced against the live server first, then fixed with a delegating property and re-verified (200 with the Cloud URL), plus a regression test asserting through the public attribute on both transports. It is in this PR because it is three lines and changes no contract; say so and it comes out.

RU · 3. Commit-хэши в отчётах устаревают за часы — процессная находка

За время этой работы `main` сдвигался трижды:

```
bd313817 → c36c8281 → 5567347 → 463ab426
```

Один из моих отчётов назвал `c36c8281` актуальным, а через несколько часов это

было уже неправдой — вы поймали это проверкой. Правило, которое я теперь применяю: **любой хэш перепроверяется через `git ls-remote` и API в момент написания**, а не берётся из памяти или предыдущего отчёта. Именно поэтому в каждом документе этого PR указан HEAD и способ, которым он получен.

EN · 3. Commit hashes go stale within hours — a process finding

`main` moved three times during this work (`bd313817 → c36c8281 → 5567347 → 463ab426). Any hash in a report is now re-verified via` git ls-remote` and the API at the moment of writing, never reused from memory or an earlier report.

RU · 4. `tests/test_workflow_actions.py::_reset_schema` — ОТКРЫТО (T-01)

Фикстура удаляет восемь таблиц, но не `schema_migrations`. Второй полный прогон на той же базе падает на `test_retry_route`: миграции считаются применёнными, `nexus_files` не пересоздаётся.

Это дефект фикстур, не продукта, и он того же класса, что и прод-проблема `0011`: сброс схемы, не сбрасывающий запись о миграциях.

Почему не в этом PR. Это чужая тестовая фикстура; правка меняет поведение прогонов, которое я не аудировал. Рекомендация: добавить `schema_migrations` в список удаляемых таблиц либо изолировать каждый модуль в собственной схеме (как делает `test_migration_runner.py`).

EN · 4. `_reset_schema` does not drop `schema_migrations` — OPEN (T-01)

A second full run against the same database fails `test_retry_route`. Fixture defect, not a product defect, and the same class as the production `0011` problem.

Not fixed: it is another author's fixture and changing it alters run behaviour I have not audited.

RU · 5. Что этот PR не содержит и почему

Не включено	Причина
Мой фронтенд (`web_ui.py`)	`main` уже имеет свой IDE-shell (`b6a0e06c`, 2432 строки, настоящие файловые маршруты, `test_ide_view.py`). Замена была бы регрессом, а не улучшением
`authz.py` + гейты	нужно решение по модели владения (см. §1)
Advisory lock	`main` уже держит exclusivity индексом `0015`; второй слой — отдельное решение, а не побочный эффект
Гейты `/api/tasks`, `/api/dashboard`	см. §1: нужна модель владения, а не патч
Правка `0011`	нельзя: она уже применена в проде, любое редактирование снова сломает checksum
`0017_lineage_reconciliation.sql`	требует read-only аудита прод-базы, которого у меня нет

EN · 5. What this PR deliberately does not contain

The frontend (main already has its own IDE shell); the authorization layer (needs an ownership-model decision); the advisory lock (main already has `0015`); any edit to `0011` (it is already applied in production, so editing it re-breaks the checksum); a `0017` reconciliation migration (needs a production audit I have no access to).